

TASK 1 – RECONNAISSANCE & VULNERABILITY SCANNING

Alfido Tech Cybersecurity Internship

Prepared by: Rupesh Thota

Target: testasp.vulnweb.com (authorized vulnerable test site)

1. Objective

The objective of this task is to perform active reconnaissance and vulnerability scanning on a safe test system. Nmap was used for port and service enumeration, while Nikto was used for web-server vulnerability and security-configuration checks. The identified findings, risks, and recommendations were documented.

2. Target & Test Environment

Target hostname: testasp.vulnweb.com

Resolved IPv4: 44.238.29.244

Target port: 80/TCP

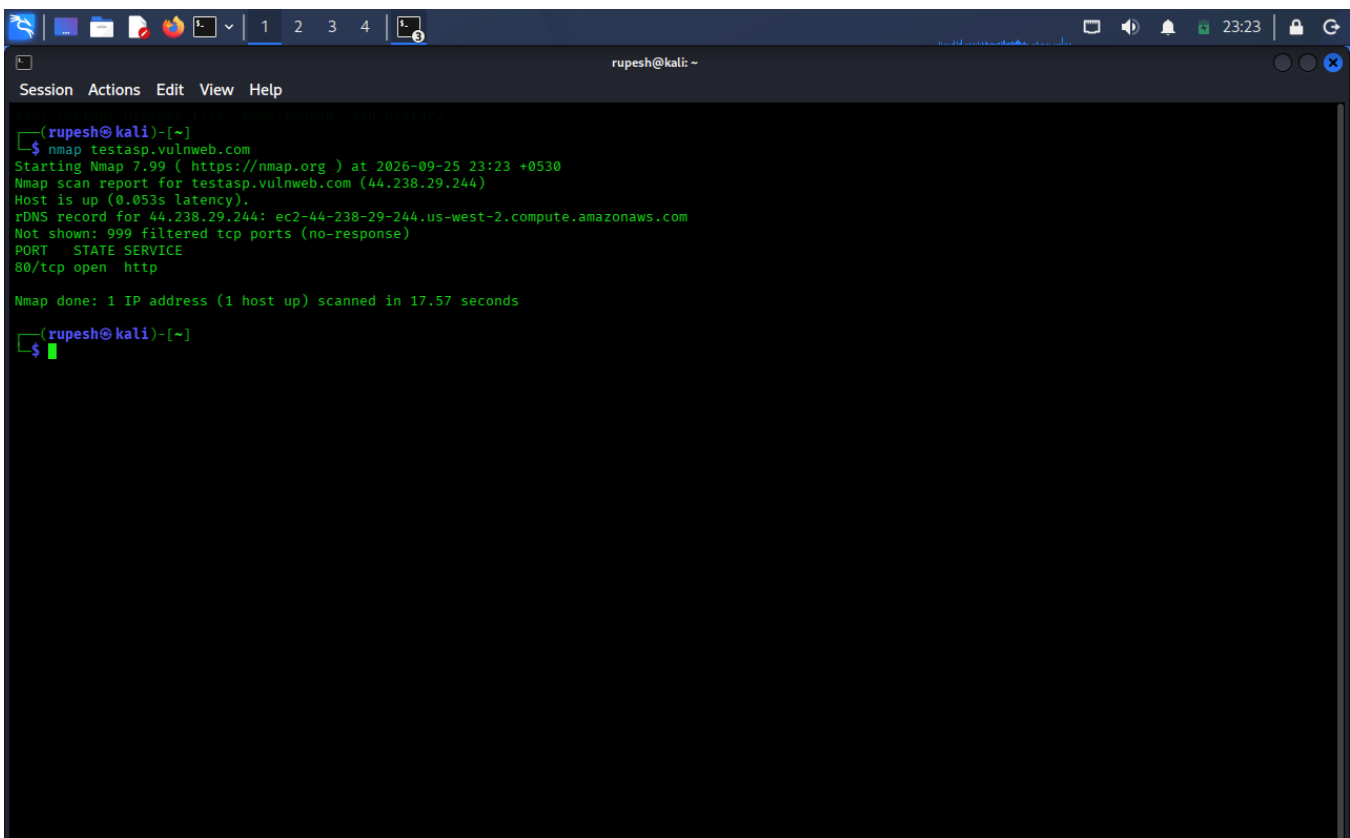
Environment: Kali Linux

Tools: Nmap 7.99, Nikto 2.6.0

3. Nmap Port Enumeration

Command: nmap testasp.vulnweb.com

The scan identified TCP port 80 as open and running HTTP. The scan also reported 999 filtered TCP ports in the default 1,000-port scan.



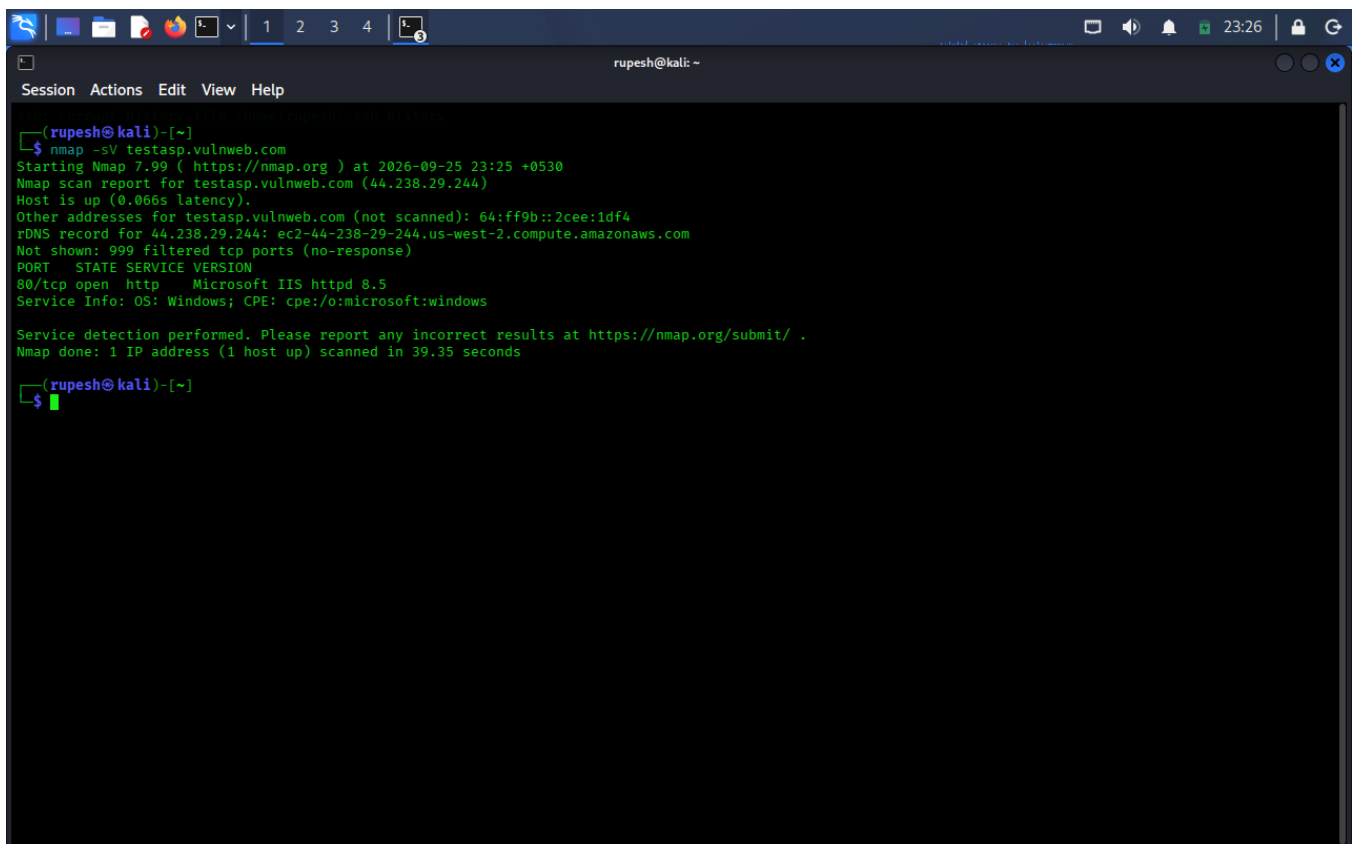
```
rupesh@kali: ~  
Session Actions Edit View Help  
[rupesh@kali]-[~]  
$ nmap testasp.vulnweb.com  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 23:23 +0530  
Nmap scan report for testasp.vulnweb.com (44.238.29.244)  
Host is up (0.053s latency).  
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 17.57 seconds  
[rupesh@kali]-[~]  
$
```

Figure 1. Nmap basic port scan.

4. Service & Version Enumeration

Command: `sudo nmap -sV testasp.vulnweb.com`

Nmap identified Microsoft IIS HTTP Server version 8.5 on TCP port 80. The scan also indicated that most other default-scanned TCP ports were filtered.

A screenshot of a Kali Linux terminal window. The terminal shows the execution of the command 'nmap -sV testasp.vulnweb.com'. The output includes the Nmap version (7.99), the target IP (44.238.29.244), and the scan results. It identifies a Microsoft IIS httpd 8.5 service on port 80. The OS is detected as Windows. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The top status bar shows the user 'rupesh@kali' and the time '23:26'.

```
(rupesh@kali)-[~]
$ nmap -sV testasp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 23:25 +0530
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.066s latency).
Other addresses for testasp.vulnweb.com (not scanned): 64:ff9b::2cee:1df4
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 8.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.35 seconds

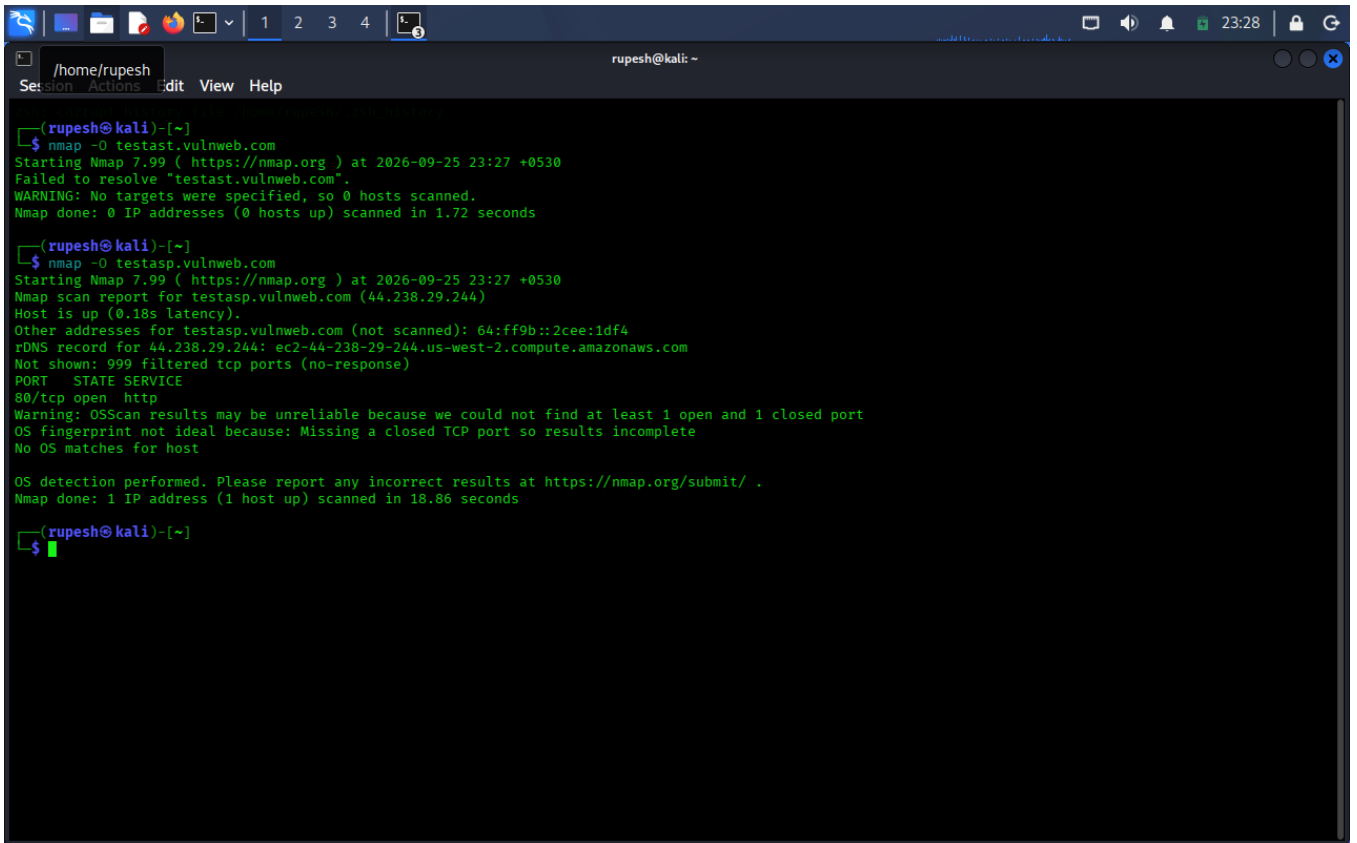
(rupesh@kali)-[~]
$
```

Figure 2. Nmap service/version detection.

5. OS Detection

Command: `sudo nmap -O testasp.vulnweb.com`

OS detection was inconclusive. Nmap reported that its OS fingerprinting could be unreliable because there was not enough open/closed port information. Therefore, this report does not claim a definitive operating system based on the Nmap OS scan.



The image shows a terminal window titled 'rupesh@kali: ~' with a menu bar containing 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal displays the following commands and output:

```
(rupesh@kali)-[~]
$ nmap -O testasp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 23:27 +0530
Failed to resolve "testasp.vulnweb.com".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 1.72 seconds

(rupesh@kali)-[~]
$ nmap -O testasp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 23:27 +0530
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.18s latency).
Other addresses for testasp.vulnweb.com (not scanned): 64:ff9b::2cee:1df4
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.86 seconds

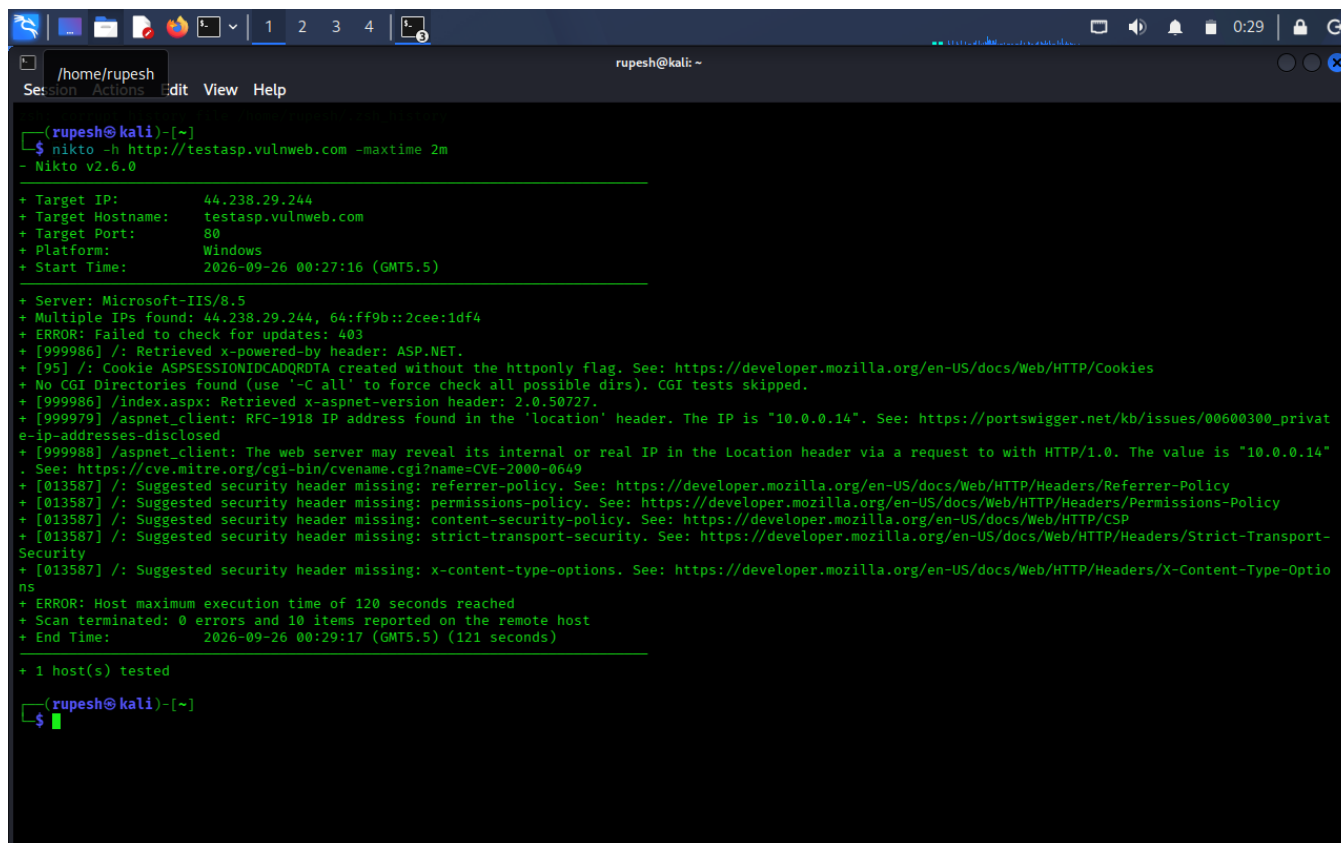
(rupesh@kali)-[~]
$
```

Figure 3. Nmap OS detection attempt.

6. Nikto Vulnerability Scan

Command: nikto -h http://testasp.vulnweb.com -maxtime 2m

The Nikto scan was run with a two-minute maximum execution time. It reached the configured time limit and reported 10 items on the remote host. The scan output identified Microsoft-IIS/8.5, ASP.NET technology disclosure, a session cookie without the HttpOnly flag, an internal IP address in a Location header, missing security headers, and public HTTP methods including TRACE.



```
(rupesh@kali)-[~]
$ nikto -h http://testasp.vulnweb.com -maxtime 2m
- Nikto v2.6.0

+ Target IP: 44.238.29.244
+ Target Hostname: testasp.vulnweb.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-09-26 00:27:16 (GMT5.5)

+ Server: Microsoft-IIS/8.5
+ Multiple IPs found: 44.238.29.244, 64:ff9b::2cee:1df4
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: ASP.NET.
+ [95] /: Cookie ASPSESSIONIDCQDQRTA created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999986] /index.aspx: Retrieved x-aspnet-version header: 2.0.50727.
+ [999979] /aspnet_client: RFC-1918 IP address found in the 'location' header. The IP is "10.0.0.14". See: https://portswigger.net/kb/issues/00600300_privat
e-ip-addresses-disclosed
+ [999988] /aspnet_client: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is "10.0.0.14"
. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-
Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Optio
ns
+ ERROR: Host maximum execution time of 120 seconds reached
+ Scan terminated: 0 errors and 10 items reported on the remote host
+ End Time: 2026-09-26 00:29:17 (GMT5.5) (121 seconds)

+ 1 host(s) tested

(rupesh@kali)-[~]
$
```

Figure 4. Nikto scan with 120-second execution limit and final summary.

7. Findings

1	ASP.NET technology disclosure	Information disclosure
2	Session cookie without HttpOnly	Cookie security
3	Internal IP 10.0.0.14 exposed in Location header	Information disclosure
4	Strict-Transport-Security missing	Security header
5	Permissions-Policy missing	Security header
6	X-Content-Type-Options missing	Security header
7	Referrer-Policy missing	Security header
8	Content-Security-Policy missing	Security header
9	TRACE listed among public HTTP methods	Server configuration

8. Security Risks

- Technology disclosure can provide useful reconnaissance information about the server stack.
- A session cookie without HttpOnly can increase exposure if client-side script execution becomes possible.
- An internal IP address in a response header discloses internal network information.
- Missing security headers reduce available browser-side security hardening.
- An unnecessary TRACE method can increase the web server's exposed attack surface.

9. Recommendations

1. Remove unnecessary technology-identifying response headers where practical.
2. Configure sensitive session cookies with the HttpOnly attribute.
3. Prevent internal IP addresses from being exposed in HTTP response headers.
4. Configure appropriate security headers, including CSP, Referrer-Policy, Permissions-Policy, and X-Content-Type-Options.
5. Enable HSTS when the application is correctly deployed over HTTPS.
6. Disable unnecessary HTTP methods such as TRACE where they are not required.
7. Keep web-server and application components maintained and updated.

10. Conclusion

The reconnaissance and vulnerability scanning exercise identified an HTTP service on TCP port 80 and Microsoft IIS 8.5 through service enumeration. Nikto identified several information-disclosure and web-security configuration observations, including an exposed internal IP address, a session cookie without the HttpOnly attribute, missing security headers, and the availability of the TRACE method. The findings were documented together with their potential security implications and recommended mitigations.

Scan limitation: The Nikto run used a 120-second maximum execution time. It reached that limit and reported 10 items; therefore, this report does not claim that every possible Nikto check completed.